Phase 4: ER Diagram, DFD, and Trust Boundary Diagram

Course Code: 20CYS401

4.1 Entity-Relationship Diagram (from actual SQLAlchemy models)

```
erDiagram
USERS {
int id PK
string username UK
string email UK
string password_hash
boolean is_admin
datetime created_at
}

BOOKS {
int id PK
string title
string author
string genre
string isbn UK
text description
int publication_year
datetime created_at
}

REVIEWS {
int id PK
int book_id FK
int user_id FK
int rating
text content
boolean is_moderated
string moderation_reason
int moderated_by FK
datetime created_at
datetime updated_at
}

READING_LIST_ITEMS {
int id PK
int user_id FK
int book_id FK
string status
datetime added_at
datetime updated_at
}

AUDIT_LOGS {
int id PK
datetime timestamp
int user_id FK
string username
string action
string resource_type
string resource_id
string ip_address
string status
text details
}

USERS ||--o{ REVIEWS : "authors"
USERS ||--o{ READING_LIST_ITEMS : "maintains"
USERS ||--o{ AUDIT_LOGS : "generates"
BOOKS ||--o{ REVIEWS : "has"
BOOKS ||--o{ READING_LIST_ITEMS : "included in"
```

```
USERS ||--o{ REVIEWS : "moderates (moderated_by)"
```

Note: All entities are directly derived from `app/models/` — User, Book, Review, ReadingListItem, AuditLog.

4.2 Level-0 DFD (Context Diagram)

```
graph LR
E1((USER\nActor))
E2((ADMINISTRATOR\nActor))
E3((Browser\nClient))

subgraph "Book Review Platform [Trust Boundary]"
P0[Book Review\nPlatform\nSystem]
D01[(D01: SQLite\nDatabase)]
end

E1 -->|Searches, rates, reviews, reads shelf| E3
E2 -->|Manages books, moderates content| E3
E3 -->|HTTPS Requests + CSRF Tokens| P0
P0 -->|HTML Responses + Security Headers| E3
P0 -->|Reads/Writes| D01
```

4.3 Level-1 DFD (Process Decomposition)

```
graph TD
E1((USER))
E2((ADMIN))

subgraph "Secure Application Trust Boundary"
P01[DFD-P01\nAuthenticate\n& Session Mgmt]
P02[DFD-P02\nSearch Book\nCatalog]
P03[DFD-P03\nView Book\nDetails]
P04[DFD-P04\nSubmit/Edit/Delete\nReview & Rating]
P05[DFD-P05\nManage\nReading List]
P06[DFD-P06\nAdmin: Catalog\n& Moderation]
P07[DFD-P07\nRecord Audit\nEvent]

D01[(D01: Users)]
D02[(D02: Books)]
D03[(D03: Reviews\n& Ratings)]
D04[(D04: Reading\nLists)]
D05[(D05: Audit Logs)]
end

E1 -->|Credentials| P01
P01 -->|Session Cookie| E1
P01 -->|Read/Write| D01
P01 -->|Log Auth Events| P07

E1 -->|Search Query| P02
P02 -->|Parameterized Query| D02
D02 -->|Book Records| P02

P03 -->|Book Detail + Review List| E1
P03 -->|Read| D02
P03 -->|Read| D03

E1 -->|Rating + Review Text| P04
P04 -->|Ownership Check| D01
P04 -->|Write| D03
P04 -->|Log Review Event| P07

E1 -->|Shelf Ops| P05
P05 -->|Ownership Check| D01
P05 -->|Write| D04
```

```
P05 -->|Log Shelf Event| P07

E2 -->|Admin Actions| P06
P06 -->|RBAC Check| D01
P06 -->|Write| D02
P06 -->|Write| D03
P06 -->|Log Admin Event| P07

P07 -->|Sanitized Event| D05
```

4.4 Trust Boundary Diagram

```
graph TD
subgraph "External Zone [Untrusted]"
B1[Browser / HTTP Client]
AT1[Potential Attacker]
end

subgraph "Application Trust Boundary"
subgraph "Authentication Layer"
AUTH[Flask-Login Session\nBcrypt Hash Verification\nHttpOnly + SameSite Cookies]
end
subgraph "Authorization Layer"
AUTHZ[RBAC Decorator @admin_required\nObject-Level Check review.is_owned_by]
end
subgraph "Business Logic Layer"
SERV[ReviewService\nBookService\nSearchService\nReadingListService]
end
subgraph "Data Access Layer"
ORM[SQLAlchemy ORM\nParameterized Queries Only]
end
end

subgraph "Data Trust Boundary [SQLite]"
DB[(SQLite Database\nbook_platform.db)]
end

B1 -->|HTTPS + CSRF Tokens| AUTH
AT1 -.->|Attempted IDOR, XSS, SQLi| AUTH
AUTH -->|Authenticated Session| AUTHZ
AUTHZ -->|Authorized Request| SERV
SERV -->|ORM Calls| ORM
ORM -->|Parameterized SQL| DB
```

4.5 Sensitive Information Flows (Min. 3 Assets)

| Asset ID | Flow | Source → Destination | Protection |

|---|---|---|---|

| ASSET-01 (Credentials) | Login: password string → bcrypt.checkpw() → user session | Browser → DFD-P01 → D01 | Bcrypt rounds=12, never stored/logged in plaintext |

| ASSET-04 (Reviews) | Review create: raw text → sanitize_text() → ORM → DB | USER → DFD-P04 → D03 | Length limit, null-byte strip, Jinja2 autoescaping on output |

| ASSET-07 (Admin Privileges) | Admin route: request → @admin_required → is_admin flag check | ADMIN → DFD-P06 → D01 | Server-side RBAC, no client-controllable flag, custom 403 on fail |